Alert ticket A-2703

Ticket ID	Alert message	Severity	Details	Ticket status
A-2703	SERVER-MAIL Phishing attempt possible download of malware	Medium	The user may have opened a malicious email and opened attachments or clicked links.	Escalated

Ticket comments	I am escalating this ticket to a level-two SOC analyst. The alert fired on a possible phishing email sent to the HR mailbox. After reading the message and checking the attachment I think it is a real attack and not a false positive. Here is what does not add up. The sender's display name is "Def Communications", but the message is signed "Clyde West". The sender address is a long string of random characters on a .su domain, which is not what a job applicant would use. The subject and the body have spelling and grammar mistakes ("Egnieer", "Ingergy", "writing for to express"), and the company name in the greeting is not spelled like the domain the message was sent to. The email says a resume and a cover letter are attached, but the only attachment is bfsvc.exe, which is an executable file. The body also gives a password to open it, which is a known way to keep mail scanners from looking inside a file. The file hash in the ticket matches a known malicious file in the threat intelligence lookup. The ticket says the user may have opened the attachment, and until someone shows otherwise I am treating that machine as compromised. The alert severity is medium, but a malicious file that may have been run is more serious than that, so I suggest raising it to high. Level two should isolate the host, check what the file did once it ran, and look for other copies of this email in other mailboxes.

Additional information

Sender	Def Communications, 76tguyhh6tgftrt7tg.su (114.114.114.114)
Recipient	hr@inergy.com (176.157.125.93)
Sent	Wednesday, July 20, 2022, 09:30:14 AM
Subject	Re: Infrastructure Egnieer role
Attachment	bfsvc.exe
File hash (SHA-256)	54e6ea47eb04634d3e87fd7787e2136ccfbcc80ade34f246a12cf93bab527f6b
Note	The email body contains the password for the attachment. I left it out of this document on purpose.

How I followed the phishing playbook

Playbook step	What I did	Result
2. Evaluate the alert	Read the severity, the sender and receiver details, the subject line and the body. I did not open anything on my own device.	Several red flags, listed in the ticket comments
3.0 Links or attachments?	Looked at what came with the email.	One executable attachment, no links
3.1 Malicious?	Checked the file hash with a threat intelligence tool.	Known malicious file
3.2 Update and escalate	Wrote a summary of the findings, set the status to Escalated and passed it to level two.	Done
4. Close the ticket	Does not apply, because the attachment is malicious.	Ticket stays open